

## Assignment Questions:

### 1. What are the pillars of Wi-Fi security?

#### 1. Authentication

Authentication is the first gatekeeper. It ensures that only authorized devices and users can join the network.

- **Mutual Authentication:** Modern standards like WPA3 and 802.1X ensure that not only does the user prove themselves to the network, but the **network also proves it is legitimate** to the user (preventing "Evil Twin" attacks).
- **Methods:** This ranges from simple Pre-Shared Keys (PSK) for homes to robust Certificate-based authentication (EAP-TLS) for enterprises.

#### 2. Confidentiality / Encryption

Since radio waves can be intercepted by anyone with an antenna, the data must be unreadable to unauthorized parties.

- **Mechanism:** Encryption transforms plain text into "cipher text" using complex algorithms.
- **Evolution:** \* **WEP:** Used RC4 (now easily cracked).
  - **WPA2:** Introduced **AES-CCMP**, a government-grade encryption standard.
  - **WPA3:** Uses **AES-GCMP**, which is even more efficient and secure for high-speed networks.

#### 3. Integrity

Integrity ensures that a hacker hasn't intercepted a packet mid-air, modified its contents (like changing the amount in a bank transfer), and sent it on its way.

- **MIC (Message Integrity Check):** Every Wi-Fi frame includes a cryptographic "seal." If even a single bit of the data is changed during transmission, the seal will break, and the receiver will discard the packet.
- **Replay Protection:** It also ensures that a captured valid packet cannot be "re-played" later to trick the system.

### 2. Explain the difference between authentication and encryption in Wi-Fi security.

#### 1. Authentication

Authentication is the process of verifying a user's or device's **identity**. It answers the question: *"Are you who you say you are, and are you allowed to enter?"*

- **When it happens:** At the very beginning of the connection process.
- **Purpose:** To prevent unauthorized users from joining the network.
- **How it works:** It uses credentials like a passphrase (WPA2-PSK), a username and password, or digital certificates (802.1X/Enterprise).
- **Outcome:** If successful, the device is "associated" with the Access Point (AP).

## 2. Encryption

Encryption is the process of scrambling data into an unreadable format. It answers the question: *"Once you are inside, can anyone else overhear what you are saying?"*

- **When it happens:** Throughout the entire duration of the connection, for every single packet sent.
- **Purpose:** To provide **Confidentiality**. It ensures that if an attacker "sniffs" the wireless signal, they cannot read your emails, passwords, or bank details.
- **How it works:** It uses mathematical algorithms (like **AES**) and a set of keys generated during the 4-way handshake to scramble the data.
- **Outcome:** The data becomes "Ciphertext," which can only be unscrambled by the intended receiver who has the correct key.

### 3. Explain the differences between WEP, WPA, WPA2, and WPA3.

#### 1. WEP (Wired Equivalent Privacy) – The Obsolete Standard

Introduced with the original 802.11 standard in 1997, WEP was intended to provide the same level of security as a wired LAN.

- **Encryption:** Uses the **RC4** stream cipher.
- **Key Management:** Uses static keys that never change.
- **Major Flaw:** The "Initialization Vector" (IV) was too short (24 bits). An attacker could capture enough packets in a few minutes to mathematically crack the password.
- **Status: Highly Insecure.** It can be cracked in seconds with modern tools.

#### 2. WPA (Wi-Fi Protected Access) – The Quick Fix

WPA was released in 2003 as a temporary "patch" for WEP's flaws. It was designed to run on the same old hardware that WEP used.

- **Encryption:** Still used **RC4**, but introduced **TKIP** (Temporal Key Integrity Protocol).
- **Key Management:** TKIP changed the key for every single packet, making it much harder to crack than WEP.
- **Status: Deprecated.** While better than WEP, TKIP itself was eventually found to have vulnerabilities.

#### 3. WPA2 (Wi-Fi Protected Access 2) – The Gold Standard

Released in 2004, WPA2 became the industry standard for nearly 15 years. It required a hardware upgrade for many because it moved away from the old RC4 algorithm.

- **Encryption:** Introduced **AES (Advanced Encryption Standard)**, specifically via the **CCMP** protocol.
- **Key Management:** Introduced the **4-Way Handshake** to derive unique session keys for every device.

- **Major Flaw:** Vulnerable to "offline dictionary attacks" and the **KRACK** (Key Reinstallation Attack) vulnerability. If a hacker captures the handshake, they can try millions of passwords against it on their own computer.
- **Status: Widely Used**, but currently being phased out by WPA3.

#### 4. WPA3 (Wi-Fi Protected Access 3) – The Modern Standard

Released in 2018, WPA3 is the most secure version of Wi-Fi available today. It is mandatory for **Wi-Fi 6** and **Wi-Fi 7**.

- **Encryption:** Uses **GCMP-256** (an even faster/stronger version of AES).
- **Key Management (Personal):** Replaced the vulnerable PSK handshake with **SAE** (Simultaneous Authentication of Equals).
- **Key Management (Enterprise):** Uses 192-bit cryptographic strength for highly sensitive environments.
- **Major Improvement:** Even if you have a weak password, a hacker cannot crack it offline. It also provides **Forward Secrecy**, meaning that even if an attacker discovers the password later, they cannot decrypt data they recorded in the past.
- **Status: Most Secure.** Recommended for all new networks.

#### 4. Why is WEP considered insecure compared to WPA2 or WPA3?

##### 1. Weak Encryption Algorithm (RC4)

WEP uses the **RC4** stream cipher, which scrambles data bit-by-bit. While RC4 isn't inherently "broken," the way WEP implemented it was very poor.

- **WPA2/WPA3:** Use **AES** (Advanced Encryption Standard), a block cipher that is globally recognized as "unbreakable" by modern standards.

##### 2. Small and Reused Initialization Vectors (IVs)

An IV is a random number added to the password to ensure that if you send the same message twice, the encrypted result looks different.

- **The WEP Problem:** WEP used a tiny **24-bit IV**. On a busy network, this means the same "random" number would repeat every few thousand packets.
- **The Exploit:** Hackers use tools (like Aircrack-ng) to collect these repeating IVs. Once they have enough (usually within a few minutes), they can perform a mathematical "statistical attack" to reveal the actual Wi-Fi password.
- **WPA2/WPA3:** Use a **48-bit IV** or higher and more complex key-mixing functions (like **TKIP** in WPA or **CCMP** in WPA2), making IV reuse attacks impossible.

##### 3. Static Key Management

In a WEP network, the password you type into your device is used directly to encrypt every single packet for as long as you are connected.

- **The Risk:** Since the key never changes, an attacker has an infinite amount of time to collect data and try to crack it.

- **WPA2/WPA3:** Use a **4-Way Handshake** to create **Temporary Keys**. Even if you have a static password for the network, each device uses a unique, temporary session key that changes constantly.

#### 4. Lack of Integrity Protection

WEP uses a simple checksum called **CRC-32** to ensure data hasn't been tampered with.

- **The Vulnerability:** CRC-32 was designed to detect accidental errors (like line noise), not intentional hacking. An attacker can actually modify a WEP packet in mid-air and recalculate a valid CRC-32 checksum so the receiver never knows the data was changed.
- **WPA2/WPA3:** Use **MIC (Message Integrity Check)** or **GMAC**, which are cryptographically secure. An attacker cannot modify the data without breaking the "digital seal."

#### 5. Why was WPA2 introduced?

##### 1. To Implement AES Encryption

The single biggest reason for WPA2 was the shift to **AES (Advanced Encryption Standard)**.

- **The Need:** WEP and the first WPA used the RC4 algorithm, which had become mathematically "leaky" and easy to predict.
- **The Solution:** WPA2 introduced **CCMP** (Counter Mode with Cipher Block Chaining Message Authentication Code Protocol), which uses AES. This provided a level of security so high that it was approved for protecting classified government data.

##### 2. To Fix the "Patchwork" of WPA

WPA (the first version) was just a software patch designed to keep old WEP hardware running. It wasn't a permanent solution.

- **WPA2 was a clean slate:** It required hardware-based encryption chips to handle the complex math of AES. This made the security robust rather than just "bolted on."

##### 3. To Ensure Data Integrity

Older standards used weak checksums (CRC-32) that hackers could easily manipulate to alter data in mid-air.

- **WPA2's fix:** It used a much stronger **Message Integrity Check (MIC)**. This ensured that if a hacker changed even a single bit of a packet while it was traveling through the air, the receiver would detect the tampering and drop the packet immediately.

##### 4. To Standardize Enterprise Security

WPA2 formalized the use of **802.1X/EAP** for large organizations.

- It allowed businesses to move away from "one password for everyone" to a system where every employee had their own unique login, verified by a **RADIUS server**. This made it possible to revoke access for a single person without changing the password for the entire company.

6. What is the role of the Pairwise Master Key (PMK) in the 4-way handshake?

### 1. How the PMK is Created

The PMK is created differently depending on whether you are at home or at work:

- **Personal Mode (WPA2-PSK):** The PMK is derived directly from your Wi-Fi password (passphrase) and the network name (SSID) using a mathematical function called PBKDF2.
- **Enterprise Mode (802.1X):** The PMK is generated dynamically and sent to the Access Point by the **RADIUS server** after you successfully log in with your username and password.

### 2. The Role of the PMK in the 4-Way Handshake

The PMK itself is **never** sent over the air. Sending it would be like mailing your house key to a friend—it's too risky. Instead, its role is to serve as the "shared secret" that both the Client and the AP use to prove they know the password.

#### A. Key Derivation (Creating the PTK)

The most important job of the PMK is to help create the **Pairwise Transient Key (PTK)**. The PTK is the actual key that encrypts your individual data packets.

#### B. Mutual Authentication

The PMK allows the client and AP to "prove" they have the right password without ever saying it. During the handshake, they use the PMK to sign messages. If the AP can verify the client's signature, it knows the client has the correct PMK (and therefore the correct password).

### 3. Why is it called "Pairwise"?

It is "Pairwise" because it is unique to the **pair** of devices (the specific Client and the specific AP). Even if ten people are on the same home Wi-Fi using the same password, they each technically establish a unique session context based on that shared PMK.

7. How does the 4-way handshake ensure mutual authentication between the client and the access point?

The **4-way handshake** ensures mutual authentication by requiring both the client and the Access Point (AP) to prove they possess the **Pairwise Master Key (PMK)** without ever actually transmitting the key itself over the air.

It uses a "challenge-response" mechanism involving random numbers (nonces) and digital signatures called **MICs (Message Integrity Checks)**.

#### How Mutual Authentication is Achieved

The handshake consists of four messages that confirm both sides are legitimate:

#### 1. The AP Proves Itself (Message 1 & 2)

- **Message 1:** The AP sends a random number called the **Anonce** (Authenticator Nonce) to the client.

- **The Proof:** The client takes that Anonce, creates its own random number (**Snonce**), and uses the **PMK** (the password-based key) to generate the **PTK** (Pairwise Transient Key).
- **Message 2:** The client sends its **Snonce** back to the AP, but it also attaches a **MIC** (a cryptographic signature).
- **The Result:** The AP uses the Snonce and its own PMK to calculate the PTK. If the AP's calculated PTK matches the MIC sent by the client, the AP has successfully authenticated the client.

## 2. The Client Proves the AP is Real (Message 3)

- **Message 3:** The AP sends a message to the client containing its own **MIC**.
- **The Proof:** The client checks this MIC using the PTK it just created.
- **The Result:** If the MIC is valid, the client knows for a fact that the AP possesses the correct PMK. This prevents "Rogue AP" attacks where a hacker tries to pretend to be your router; since the hacker doesn't know your Wi-Fi password (the PMK), they cannot generate a valid MIC for Message 3.

## 4. Confirmation (Message 4)

- **Message 4:** The client sends a final confirmation to the AP that the keys are installed and ready to be used for data encryption.

## 8. What will happen if we put a wrong passphrase during a 4-Way handshake?

If you enter the wrong passphrase, the **4-Way Handshake will fail**, but it doesn't fail at the very beginning. Because of how the handshake is structured, the "failure" actually manifests during the second or third step.

Here is the exact technical sequence of what happens when the password is incorrect:

### 1. The Handshake Breakdown

- **Message 1 (Success):** The Access Point (AP) sends the **Anonce** (random number) to the client. This always succeeds because the Anonce doesn't require a password to be sent.
- **The Calculation (The Error):** The client uses the **wrong passphrase** to derive a **wrong PMK** (Pairwise Master Key). It then uses that wrong PMK to calculate a **wrong PTK** (Pairwise Transient Key).
- **Message 2 (The Failure Point):** The client sends its **Snonce** and a **MIC** (Message Integrity Check) back to the AP.
  - The MIC is a digital signature created using the (wrong) PTK.
  - When the AP receives Message 2, it uses its **correct PMK** to calculate the **correct PTK**.
  - The AP then checks the MIC. Since the client used a different password, the MICs won't match.

### 2. The Result: Deauthentication

When the AP detects the MIC mismatch in Message 2, the following occurs:

1. **Handshake Termination:** The AP realizes the client does not have the correct "shared secret" (the password).
2. **Deauthentication Frame:** The AP sends a **Deauthentication management frame** to the client.
3. **Error Code:** The frame usually contains a Reason Code (often **Reason Code 2: Previous authentication no longer valid** or **Reason Code 15: 4-Way Handshake timeout**).
4. **Disconnection:** The client is kicked back to "State 1" (Unauthenticated/Unassociated) and will usually prompt the user with an "Incorrect Password" or "Authentication Failed" message.

9. What problem does 802.1X solve in a network?

### 1. The "Shared Secret" Problem

In a Pre-Shared Key (PSK) environment, the password is a single point of failure.

- **The Problem:** If one employee leaves the company or loses their laptop, the entire office's Wi-Fi password is technically compromised. To remain secure, you would have to change the password for every single employee and every single device in the building.
- **The 802.1X Solution:** It provides **Individual Accountability**. Every user has their own unique credentials (username/password or digital certificate). If an employee leaves, you simply disable their account in the central database (like Active Directory), and their access is instantly revoked without affecting anyone else.

### 2. Lack of Centralized Management

Managing Wi-Fi access on a per-device basis is impossible for large organizations.

- **The Problem:** In a standard network, the Access Point (AP) has to "know" the password. If you have 500 APs across different floors, updating or managing those passwords is a nightmare.
- **The 802.1X Solution:** It offloads the "brain" of the security to a **RADIUS Server** (Remote Authentication Dial-In User Service). The APs become "dumb" authenticators that just pass messages back and forth. All security policies are managed in one central location.

### 3. Visibility and Auditing

- **The Problem:** With a shared password, you cannot tell who is who. If someone performs a malicious act on the network, the logs just show a MAC address, not a person.
- **The 802.1X Solution:** Because users log in with unique IDs, the network logs show exactly **who** connected, **when**, and to **which AP**. This is vital for compliance in industries like healthcare (HIPAA) or finance.

### 4. Dynamic VLAN Assignment

- **The Problem:** In a basic network, everyone who joins the Wi-Fi is on the same network.
- **The 802.1X Solution:** Based on the user's login, the RADIUS server can tell the AP, "This is an HR employee, put them on VLAN 10," or "This is an Engineer, put them on VLAN 20." This happens automatically during the connection process.

10. How does 802.1X enhance security over wireless networks?

### 1. Elimination of the "Shared Key" Weakness

In a standard home network, if an attacker learns the password, the entire network is exposed.

- **Enhancement:** With 802.1X, there is no single "Master Password" for the network. Each user authenticates with their own unique credentials. Even if one person's password is stolen, the rest of the network remains secure.

### 2. Stronger Encryption Key Generation

While both WPA2-Personal and WPA2-Enterprise use the 4-way handshake, 802.1X changes how the **Pairwise Master Key (PMK)** is handled.

- **In Personal Mode:** The PMK is static (derived from the SSID and password).
- **In 802.1X:** The PMK is **dynamic and unique**. Every time a user logs in, the RADIUS server and the client negotiate a brand-new PMK. This makes it significantly harder for attackers to use pre-calculated "rainbow tables" to crack the encryption.

### 3. Support for Advanced Authentication (EAP)

802.1X uses the **Extensible Authentication Protocol (EAP)**, which allows the network to support much stronger authentication methods than just passwords:

- **EAP-TLS:** Requires a digital certificate on the device. This means even if a hacker steals a user's password, they cannot connect because they don't have the physical digital certificate installed on the hardware.
- **Multi-Factor Authentication (MFA):** 802.1X can be integrated with systems that require a phone-based approval or a hardware token to log in.

### 4. Port-Based Access Control (The "Closed Door" Policy)

Technically, 802.1X acts as a virtual "gatekeeper" at the Access Point.

- **Enhancement:** Until the user successfully authenticates with the RADIUS server, the AP blocks all traffic from that device except for the authentication packets themselves. The user cannot even get an IP address or "see" other devices on the network until they are fully cleared.

### 5. Protection Against Rogue Access Points

Because 802.1X often involves **Mutual Authentication** (specifically in methods like EAP-TTLS or PEAP), the client also verifies the network's identity.

- **Enhancement:** Your device will check the server's certificate to ensure it is connecting to the *real* company network and not a "Evil Twin" AP set up by a hacker to steal credentials.



